Security Testing Evidence Report

Cybersecurity Integrated Digital Leave Management System with Real-Time Intrusion Alerts

Local Government Unit of Alicia

Generated: 2026-10-26T22:14:25+08:00 · Automated suite: `SecurityTestMatrixTest`

Overall result: ALL SCENARIOS PASS

6 scenarios · 300 total trials · 300 passed · 0 failed

1. Overview and Methodology

This report documents the security testing conducted on the system. Six security test scenarios, drawn from the project test plan, were each executed 50 times by an automated test suite so that every result is a tally of 50 independent trials rather than a single run. In total, 300 trials were executed and all passed.

The suite exercises the system's own live security controls — the application-layer Intrusion Detection Service, the login-security (brute-force / lockout) service, and the role-based access-control middleware. Each trial records its outcome and captures representative rows from the application's own log tables (intrusion_logs, failed_logins) as evidence.

Test environment

Framework	Laravel 12 · PHP 8.3 · PHPUnit
Controls under test	IntrusionDetectionService · LoginSecurityService · PermissionMiddleware
Iterations	50 per scenario (configurable via SECURITY_MATRIX_ITERATIONS)
Assessment type	Defensive self-assessment, in-process against the project's own application
Evidence store	security-evidence.sqlite (database), runs.csv, report.html, PNG figures

2. Summary of Results

#	Scenario	Security control verified	Trials	Result
1	**Detected Vulnerabilities**	Input validation · RBAC · Authentication · Secure config	50/50	**PASS**
2	**Unauthorized Access Attempt**	OTP authentication · RBAC · Access logging	50/50	**PASS**
3	**Blocked Unauthorized Login Attempts**	Login-attempt blocking · IP / source monitoring	50/50	**PASS**
4	**SQL Injection Attempt**	Input validation · IDS signatures · Parameterized queries	50/50	**PASS**
5	**Brute Force Login Attempt**	Login blocking · OTP authentication · Intrusion logging	50/50	**PASS**
6	**Intrusion Alerts Generated**	Real-time intrusion alerts · Audit logging	50/50	**PASS**

Mean real-time alert latency (brute-force lockout → administrator notification queued): 19.32 ms across 50 trials.

Security Test Matrix — Evidence Report

Cybersecurity Integrated Digital Leave Management System · LGU of Alicia
Generated 2026-10-26T22:14:25+08:00 · Suite `SecurityTestMatrixTest`

ALL SCENARIOS PASS

6	300	300	0
SCENARIOS	TOTAL TRIALS	PASSED	FAILED

Results by scenario

#	SCENARIO	SECURITY CONTROL VERIFIED	TRIALS (PASS/TOTAL)	RESULT
1	**Detected Vulnerabilities**	Input validation · RBAC · Authentication · Secure configuration	50 / 50	PASS
2	**Unauthorized Access Attempt**	OTP authentication · RBAC · Access logging	50 / 50	PASS
3	**Blocked Unauthorized Login Attempts**	Login-attempt blocking · IP / source monitoring	50 / 50	PASS
4	**SQL Injection Attempt**	Input validation · IDS signatures · Parameterized queries	50 / 50	PASS
5	**Brute Force Login Attempt**	Login blocking · OTP authentication · Intrusion logging	50 / 50	PASS
6	**Intrusion Alerts Generated**	Real-time intrusion alerts · Audit logging	50 / 50	PASS

Mean real-time alert latency (brute-force lockout → administrator notification queued): **19.32 ms** across 50 trials.

Figure 1. Automated evidence report — results by scenario.

3. Scenario Detail and Database Evidence

3.1 Detected Vulnerabilities (endpoint sweep)

Tool / method	Automated endpoint sweep (OWASP ZAP-equivalent access-control probe)
Attack scenario	Every role-restricted endpoint requested under both an unauthenticated session and an authenticated employee-role session.
Security control	Input validation · RBAC · Authentication · Secure configuration
Expected result	No finding of high or critical severity. A restricted page served, or a 5xx server error, counts as a finding.
Pass / fail criteria	PASS: no high/critical finding in any trial. FAIL: a restricted page is served or a server error occurs.
Result (50 trials)	PASS — 50 / 50 trials, 0 findings (5 endpoints × 2 sessions probed per trial).

Endpoints probed: /users, /roles, /security, /audit-logs, /settings. Anonymous access was redirected to the login screen (302); employee access was refused (403).

3.2 Unauthorized Access Attempt

Tool / method	Manual / automated login and direct-URL testing
Attack scenario	Direct URL access to five role-restricted endpoints by an authenticated employee-role account and by an unauthenticated session.
Security control	OTP authentication · RBAC · Access logging
Expected result	Unauthorized access attempts denied.
Pass / fail criteria	PASS: unauthorized users cannot reach restricted pages. FAIL: a protected area is reached.
Result (50 trials)	PASS — 50 / 50 trials. Employee hits returned 403 and were logged as privilege-escalation events; anonymous hits were redirected to login.

Evidence — rows captured from the application's own tables during the run:

category	severity	route	method	matched_rule	ip	user_id
privilege	medium	users	GET	rbac_denied	127.0.0.1	50
privilege	medium	roles	GET	rbac_denied	127.0.0.1	50
privilege	medium	security	GET	rbac_denied	127.0.0.1	50
privilege	medium	audit-logs	GET	rbac_denied	127.0.0.1	50
privilege	medium	settings	GET	rbac_denied	127.0.0.1	50

Table: privilege-escalation rows written to intrusion_logs (one per denied endpoint).

3.3 Blocked Unauthorized Login Attempts

Tool / method	Login monitoring / system logs
Attack scenario	Twenty consecutive failed authentications against one account from a single source address within a 60-second window.
Security control	Login-attempt blocking · IP / source monitoring
Expected result	Unauthorized login attempts automatically blocked after the threshold limit.

Pass / fail criteria	PASS: repeated failures are blocked after the defined limit. FAIL: excessive failures continue without restriction.
Result (50 trials)	PASS — 50 / 50 trials. The account was blocked once the 3-attempt threshold was crossed; every attempt was recorded; a correct password afterwards was still refused.

Evidence — rows captured from the application's own tables during the run:

identifier	ip	reason	occurred_at
s3.victim50@alicia.gov.ph	198.51.0.50	invalid_password	2026-10-26T14:14:20.000000Z
s3.victim50@alicia.gov.ph	198.51.0.50	invalid_password	2026-10-26T14:14:20.000000Z
s3.victim50@alicia.gov.ph	198.51.0.50	invalid_password	2026-10-26T14:14:20.000000Z
s3.victim50@alicia.gov.ph	198.51.0.50	blocked	2026-10-26T14:14:20.000000Z
s3.victim50@alicia.gov.ph	198.51.0.50	blocked	2026-10-26T14:14:20.000000Z

Table: failed_logins rows for one source address — invalid-password attempts followed by blocked attempts.

3.4 SQL Injection Attempt

Tool / method	SQLMap-equivalent payload set / manual injection testing
Attack scenario	Ten injection payloads (tautology, UNION, and time-delay families) across query and login input fields.
Security control	Input validation · IDS signatures · Parameterized queries
Expected result	SQL injection attempts fail; no unauthorized database access occurs.
Pass / fail criteria	PASS: injection attempts are blocked and no unauthorized database access occurs. FAIL: injection bypasses validation or reaches database information.
Result (50 trials)	PASS — 50 / 50 trials. The IDS blocked and logged the classic payload shapes; every payload was additionally run through a parameterized query and returned zero rows, proving it was treated as a literal string and never executed as SQL.

Evidence — rows captured from the application's own tables during the run:

category	severity	matched_rule	payload_excerpt	ip
sqli	high	sqli_signature	--	198.51.0.50
sqli	high	sqli_signature	--	198.51.0.50
sqli	high	sqli_signature	UNION+SELECT+username, +password+FROM+users +-- x' UNION SELECT	198.51.0.50
sqli	high	sqli_signature	UNION+SELECT+NULL, +version()+-- ' UNION SELECT	198.51.0.50
sqli	high	sqli_signature	--	198.51.0.50

Table: sqli detections written to intrusion_logs (high severity, signature match).

3.5 Brute Force Login Attempt

Tool / method	Hydra-equivalent wordlist / manual brute-force testing
Attack scenario	Twenty login attempts using a password wordlist against a valid account name from a single source address.

Security control	Login blocking · IP monitoring · OTP authentication
Expected result	Brute-force attempts blocked.
Pass / fail criteria	PASS: repeated attempts are blocked after the allowed threshold. FAIL: brute-force attempts continue successfully.
Result (50 trials)	PASS — 50 / 50 trials. No wordlist entry ever produced a session; the account was blocked after the threshold and a high-severity auth_fail event was logged.

Evidence — rows captured from the application's own tables during the run:

category	severity	matched_rule	payload_excerpt	ip
auth_fail	high	lockout_threshold	Account auto-blocked: s5.sample@alicia.gov.ph	198.51.200.200

Table: the lockout event written to intrusion_logs when the threshold was crossed.

3.6 Intrusion Alerts Generated

Tool / method	Intrusion monitoring system
Attack scenario	Each attack family executed, with alert presence and audit record measured, and alert latency timed.
Security control	Real-time intrusion alerts · Audit logging
Expected result	Suspicious activities generate intrusion alerts.
Pass / fail criteria	PASS: suspicious or unauthorized activities generate real-time alerts. FAIL: intrusions occur without generating alerts.
Result (50 trials)	PASS — 50 / 50 trials. Brute-force lockouts produced an administrator lockout alert plus an audit record; SQL-injection bursts crossing the auto-block threshold produced an intrusion alert. Mean alert latency: 19.32 ms.

4. How to Reproduce

From the project root, run the three commands below. The first runs all 50 trials per scenario; the second builds the database, CSV and HTML report; the third renders the figures.

```
SECURITY_MATRIX_ITERATIONS=50 php artisan test --filter=SecurityTestMatrixTest
php scripts/security-evidence-report.php
node scripts/security-evidence-screenshots.cjs
```

Evidence files are in `docs/security-evidence/`: the queryable database (security-evidence.sqlite), the trial ledger (runs.csv), the HTML report and the PNG figures.

5. Where to Put This in the Manuscript

Chapter 3 — Methodology (Testing / Evaluation procedure)

Put the methodology paragraph and the test-environment table here. Describe the six scenarios, the 50-trial repetition, and that testing exercised the system's live security controls. This establishes rigour and repeatability. Reference the summary table as a forward pointer to Chapter 4.

Chapter 4 — Results and Discussion

Put the Summary of Results table (Section 2) and Figure 1 here as the headline finding: 6 scenarios, 300 trials, 100% pass. Then discuss each scenario briefly, citing the pass/fail criteria. The mean alert-latency figure (19.32 ms) belongs here as a performance result for the real-time alerting objective.

Chapter 4 or Appendix — Scenario detail and database evidence

The per-scenario detail cards and the captured database rows (Section 3) are your proof. If your program allows a results chapter to carry tables, keep the detail cards in Chapter 4; otherwise move Section 3 to an appendix (e.g., "Appendix G — Security Testing Evidence") and cite it from Chapter 4. The intrusion_logs and failed_logins tables are the concrete artifacts a panelist will look for.

Appendix — Raw artifacts and reproduction

Place the reproduction commands (Section 4) and screenshots of the SQLite database and HTML report in an appendix. Mention that the full ledger (runs.csv, 300 rows) and the database file are included in the submission package so the results can be independently verified.

Chapter 5 — Summary, Conclusion, Recommendation

Cite the 100% pass rate as evidence that the security objectives (intrusion detection, access control, brute-force protection, real-time alerting) were met. For recommendations, note that this is an in-process self-assessment and that an external network-level scan (OWASP ZAP / SQLMap against a running HTTPS instance) is recommended as future work — this shows maturity and pre-empts the obvious panel question.

ISO/IEC 25010 — Security characteristic

Use this evidence to support the "Security" characteristic (confidentiality, integrity, non-repudiation, accountability) in your ISO 25010 evaluation chapter, and cite the per-trial pass rate alongside the respondent survey scores.

Honesty note for your defense: this is a defensive self-assessment run in-process against the project's own application, not an external penetration engagement. Where the test plan names an external tool (ZAP, SQLMap, Hydra), the suite reproduces the check that tool performs against the live controls. State this plainly in Chapter 3 so the scope is clear; it strengthens, rather than weakens, the work.